

SECURITY MANAGEMENT POA: CONCISE NOTES

Chapter 1: Enterprise Security Risk Management (ESRM)

1. Enterprise Security Risk Management (ESRM)

- 1.1. Strategic approach to Security management, that ties an organizations security practice to its overall strategy using globally accepted and established risk management principles.
- 1.2. The objective of ESRM is to identify, evaluate, and mitigate the impact of security risks to the organization with priority given to protective activities that help enable the organization to advance its overall mission.
- 1.3. ESRM is a management process **NOT** a program.

2. How is ESRM Different.

<u>Traditional Risk Management</u>	<u>ESRM</u>
Built around a security program with numerous sub-programs	ESRM addresses all security risks to an organisations assests and developing specific mitigation steps.
Addresses a specific threat or issue by a program.	ESRM does not attempt to assign a risk to a specific program.
In the traditional security management process, the security professional does what is requested or directed and implements security processes/programs.	In ESRM, asset owners own decisions for the risk to the assets they manage. Those decisions are made with the input and guidance from the security professional.

3. Benefits of ESRM. ESRM provides many benefits to the organization.

- 3.1. Enabling critical decisions around security risks at an enterprise level. supporting the organization's mission and objectives.
- 3.2. Allowing asset owners and other stakeholders to develop a greater. consistent understanding of the security function's role.
- 3.3. Providing a mechanism to elevate identified security risks to top management.
- 3.4. Better alignment of security resources and organizational strategy to effectively manage prioritized risk.
- 3.5. Improving effectiveness and efficiency of the security program.
- 3.6. Early identification and proactive monitoring of threats and vulnerabilities.
- 3.7. More effective risk prioritization and mitigation based on partnership between security and asset owners.
- 3.8. Improving engagement with stakeholders with a vested interest in the security of the organization.
- 3.9. Better support for the organization's legal. regulatory. contractual. and internal audit responsibilities.
- 3.10. Integrating security into the culture of the organization.

4. Components of ESRM. ESRM has three primary components:

- 4.1. The context of ESRM, which includes organizational aspects that security professionals must understand to successfully adopt ESRM;
- 4.2. The ESRM cycle, which is ESRM's actual process of security risk management that emphasizes the importance of understanding assets; and
- 4.3. The foundation of ESRM, which includes organizational concepts that support the ESRM approach and maximize its impact.

5. The Context of ESRM.

5.1. When implementing ESRM, security professionals should have a understanding of the organization's:

- 5.1.1. Mission and vision
- 5.1.2. Core values
- 5.1.3. Operating environment
- 5.1.4. Stakeholders.

5.2. Mission & Vision.

5.2.1. Understanding of the organization's mission and vision is critical to effectively identify risks that could impede the organization's ability to achieve its goals and objectives.

5.2.2. Security professionals need to consider the following aspects such as.

- Operating structure
- Key staff and leadership
- Products and services
- Regulations and legal requirements
- Long-term strategic goals and objectives

5.3. Core Values.

5.3.1. Organizational core values can indicate how well ESRM and its emphasis on partnership, collaboration and transparency might be embraced and supported by the corporate culture.

5.3.2. Core values may include things like environmental stewardship, the community, employee safety and security, product quality, brand and image protection and new product development.

5.3.3. Linking ESRM to the organization's core values will better ensure alignment with the priorities of top management.

5.3.4. An organization's core values are an integral component and driver of corporate culture.

5.4. Operating Environment.

5.4.1. To assess risk, it is essential that security professionals understand the environment in which the organization operates.

5.4.2. The operating environment consists of three main categories:

- **Physical:** Includes factors such as the organization's types and locations of facilities or campuses.
- **Non physical:** Includes factors such as the geo-political landscape: culture: industry pressures: legal. regulatory and compliance requirements: intensity of competition: organizational growth mode: speed of decision making: and willingness to adopt technology.
- **Logical:** Logical factors include the organization's various information types. Also included are digital assets and the network or digital space that connects them to each other and to stakeholders.

5.5. Stakeholders.

5.5.1. Any individual who interfaces with the organization may be considered a stakeholder.

5.5.2. Security professionals should know stakeholders of the organization and understand what is important to those stakeholders.

5.5.3. Examples of stakeholders include:

- Persons responsible for defining the organization's strategy
- Organizational owners of tangible and intangible assets
- Persons who are working for or on behalf of the organization
- Persons who contribute knowledge or support to the organization: el Clients/constituents of the organization:
- Surrounding communities impacted by the organization.

5.5.4. Understanding stakeholders does not necessarily mean harmonizing their interests, but rather understanding their needs and their risk insights to better execute the ESRM cycle.

6. ESRM Cycle.

6.1. The ESRM Cycle is the part of the ESRM approach that describes how security risks are to be mitigated.

6.2. Its most defining characteristic is its emphasis on understanding organizational assets and involving asset owners in the risk management process.



6.3. The ESRM Cycle includes four processes:

- Identify and prioritize assets
- Identify and prioritize risks
- Mitigate prioritized risks
- Continuous improvement.

6.4. **Step – I : Identify & Prioritize Assets.**

6.4.1. Asset prioritization is based on each asset's criticality to the organization's mission and overall strategy. Based on inputs from asset owners and other stakeholders.

6.4.2. The resulting prioritized lists of assets is the basis for the remainder of the ESRM Cycle.

6.4.3. Key roles to understand throughout the ESRM Cycle include:

- **Asset owner**

- Person most directly responsible for successful operation of the asset.
- **ESRM assigns responsibility for the risk to an asset to the asset owner.**
- The asset owner is the risk owner.

- **Top management.** Highest level of executive leadership in an organization.

- **Security professional.** Acts as a security risk subject matter expert and a trusted advisor to asset owners, top management, and other stakeholders.

6.5. **Step – II : Identify & Prioritize Risks.**

6.5.1. Risk prioritization is based on each risk's potential to undermine the organization's ability to execute its mission and overall strategy.

6.5.2. Risk prioritization is based in part on guidance from top management and input from other stakeholders.

6.5.3. 'The resulting prioritized lists of risks & prioritized list of assets, form a set of strategic priorities throughout the entire ESRM cycle and help guide asset owner decisions.

6.6. **Step – III : Mitigate Prioritized Risks.**

6.6.1. Risks are mitigated in order of priority, using security controls recommended by the security professional and approved by the asset owner.

6.6.2. Asset owners make the decisions with guidance from the security professional.

6.6.3. **The plan is ultimately executed by the security professional.**

6.7. **Step – IV : Continuous Improvement.**

6.7.1. Spans the entire ESRM Cycle.

6.7.2. Continuous improvement of the security program occurs because of ESRM outcomes such as improved communication, greater visibility into security risks, and effective risk prioritization and mitigation.

Chapter – 2: Introduction to Enterprise Assets Protection (EAP)

1. Defining Assets Protection.

1.1. Security professionals have traditionally spoken of protecting three types of assets: people, property, and information.

1.2. The larger view of assets protection has also considered intangible assets, such as an organization's reputation, relationships, and creditworthiness.

1.3. **Types of Assets** : tangible assets-those that can be seen, touched, or directly measured —and in intangible assets, which have no physical form.

2. Risk Mitigation Techniques.

- 2.1. ***Eliminate***: Some risk can be eliminated entirely by not conducting the activity which generates the risk. Eliminating a risk is not always practical or possible.
- 2.2. ***Reduce***: Reducing risk is a common action associated with security. Risk can be reduced through a variety of strategies designed to mitigate the effects of an attack and/or the resulting loss. Most of the functions associated with security are aimed at reducing risk.
- 2.3. ***Transfer***: The transfer of risk is typically achieved through insurance and implies that another entity is taking on the risk on the organization's behalf.
- 2.4. ***Accept***: Risk is a normal part of everyday life, and some risk is simply accepted as part of day-to-day operations.

3. The Four D's. In this concept, the assets protection strategy is to deter, deny, detect, and delay.

- 3.1. ***Deter***. The first objective is to deter any type of attack.
- 3.2. ***Deny***. The second objective is to deny the adversary access to the asset.
- 3.3. ***Detect***. The third objective, if the first two fail, is to detect the attack or situation, often using surveillance and intrusion detection systems, human observation, or a management system that identifies shortages or inconsistencies.
- 3.4. ***Delay***. Once an attack or attempt is in progress, the fourth objective is to delay the perpetrator using physical security and target hardening methods.

Chapter 3 : Theft & Fraud Prevention in the Workplace

1. Theft & Fraud.

- 1.1. Elements of economic crime – ***motive, ability, opportunity***.
- 1.2. ***Theft*** – Dishonest appropriation of property belonging to another person.
- 1.3. ***Fraud*** – Intentional deception perpetrated for the purpose of unlawfully taking others property/ Theft by deception.
- 1.4. Loss should not merely be calculated in the terms of revenue. Loss should be measured by considering the potential sales lost and other costs such as downtime and insurance rate changes necessary to cover the loss.
- 6.5. Percentage of loss can be calculated based on the loss history of the organization
- 6.6. ***General Characteristics*** : Employees + Lack of supervision / process = loss of time, good, intellectual property
- 6.7. ***Types of Fraud*** : Asset misappropriation, corruption, financial statement fraud.

7. Motivation to conduct Theft & Fraud.

- 2.1. ***Causes*** : External economic pressures, youth & work, opportunity, job dissatisfaction, social control.

2.2. Theories of White Collar Crime.

- 2.2.1. **Edwin Sutherland** – differential association theory (criminal behavior associated with criminal environment)
- 2.2.2. **Donald Cressy** – Non sharable need theory (Violation of position of financial trust).

8. Fraud & Related Crimes.

- 3.1. **Common elements of fraud** : financial pressure, opportunity, justification for fraud.
- 3.2. Workplace theft – **spontaneous**, fraud – **premeditated**
- 3.3. **Predominant factor for fraud** – **Greed**, desire to appear successful, financial pressures
- 3.4. Proving fraud can be difficult. The factfinder must demonstrate the following:
 - 3.4.1. The perpetrator misrepresented or concealed a material fact.
 - 3.4.2. The perpetrator knew the representation was false.
 - 3.4.3. The perpetrator intended the victim to rely on the falsity.
 - 3.4.4. The victim relied on the misrepresentation.
 - 3.4.5. The victim was damaged by his reliance on the misrepresentation.

9. Fraud Symptoms & Indicators.

- 4.1. **Opportunity for fraud** - absence or weakness of internal controls.
- 4.2. **Red Flags** – Employee Situational, Employee Opportunity, Organizational Situation, Organizational Opportunity.

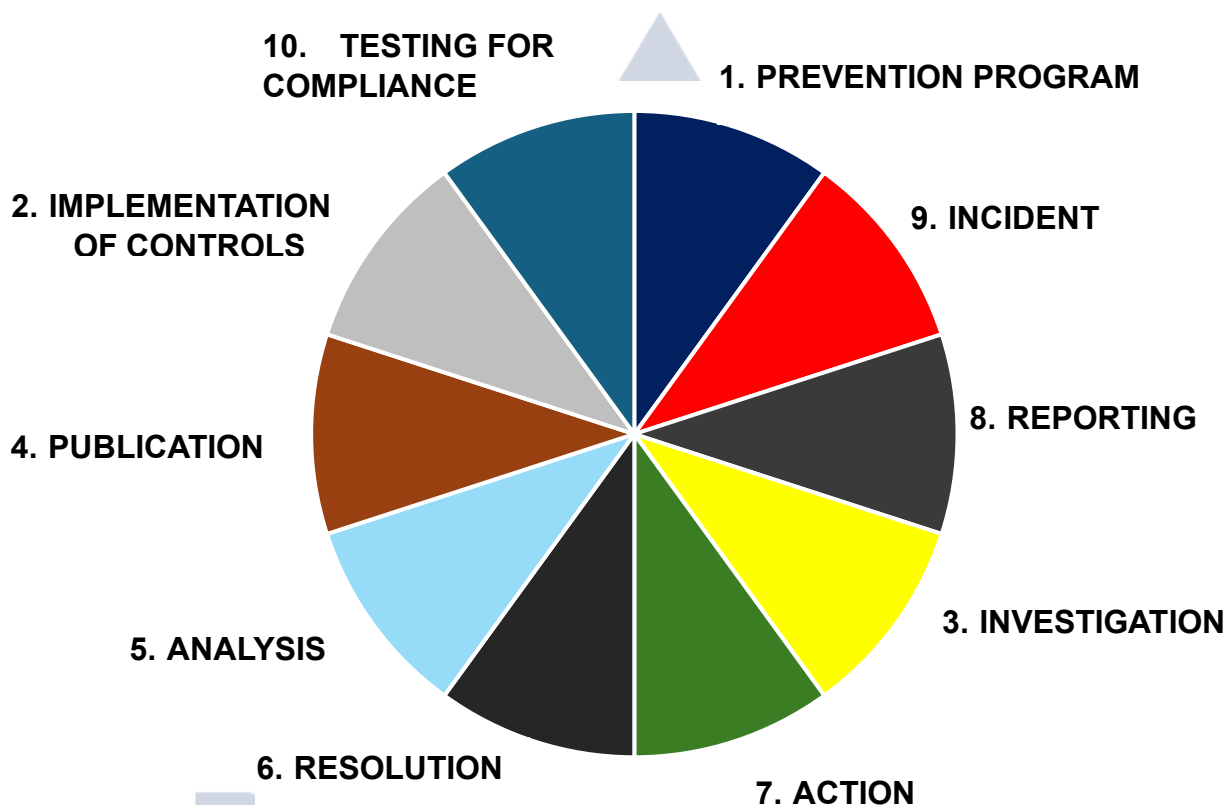
5. Model prevention Program.

- 5.1. To prevent theft and fraud, organizations must move from a reactive to a **proactive approach**.
- 5.2. Process most companies follow when theft losses are identified.
 - 5.2.1. An incident of theft or fraud is discovered.
 - 5.2.2. Investigative resources are identified, and an investigation is initiated.
 - 5.2.3. Action is taken based on the result of the investigation.
 - 5.2.4. The issue is resolved by temporarily tightening controls, replacing terminated employees, etc.
- 5.3. **Lapping** : Pocketing of small amounts from incoming invoice payments and then applying subsequent payment to cover the missing cash from the previous invoice, and so on.
- 5.4. **Kitting** is any sort of fraud that involves drawing out money from a bank account that does not have sufficient funds to cover the check.
- 5.5. **Conversion** is a term used for the receiving of money or property and fraudulently withholding or applying it for one's own use.

6. Response strategy.

- 6.1. Convening a cross functional Quick Reaction Team. This team addresses immediate problem including revoking access credentials.
- 6.2. Investigate why the theft occurred.
- 6.3. Conduct a root cause analysis.
- 6.4. Develop a remediation Plan.

7. **Comprehensive Model for Theft & Fraud Prevention.**



- 7.1. **Prevention Programs.** Designed to teach management and employees about the nature, types and most vulnerable areas of losses.
- 7.2. **Incident.** An indicator of the effectiveness of prevention efforts is the quick and accurate reporting of suspected thefts and fraud.
- 7.3. **Incident Reporting.** Employees should be encouraged to report theft and fraud even without a monetary reward. Fostering a culture of integrity and honesty is the best practice.
- 7.4. **Investigation.** Investigations are more successful when investigative roles and responsibilities are clearly defined. The main objective of any preliminary investigation is to determine what crime or violation exists.
- 7.5. **Action.** Action based on a fair and impartial review of the facts determined by a thorough investigation. Taking **immediate action** against theft and fraud perpetrators is one of the **strongest deterrents** to future losses.

7.6. **Resolution.** Resolution of the case may include determining the appropriate discipline for guilty employees, estimating the actual loss, reporting the loss to an insurance carrier, and performing other steps to close the investigation and obtain a recovery.

7.7. **Analysis.** The concern here is how and why the loss occurred - in other words, the dynamics involved from a human and control standpoint.

7.8. **Publication.** Organizations can use newsletters or bulletins to inform employees of incidents and their resolution and show how the security organization provides value to the company.

7.9. **Implementation of Controls.** Additional controls may prevent future thefts. Controls must be cost-effective and based on a solid analysis of the loss.

7.10. **Compliance Testing & Training.** periodic testing or auditing for compliance with existing controls. Achieved through audits (by internal or external auditors), security reviews by the company's security department, or, as a last resort, the use of undercover operations.

Chapter - 4 : Cost Effectiveness & Loss Reporting

1. Cost effectiveness

1.1. Cost-effectiveness means producing good results for the money spent.

1.2. Maximize cost effectiveness –

1.2.1. Operations conducted in least expensive way

1.2.2. Maintain lowest costs with required op results

1.2.3. Ensuring higher return

1.3. Cost-effectiveness also requires balancing expenditures against results and revising the plan as needed.

2. Elements of Cost effectiveness.

2.1. Maj loss Prevention – Cost Avoidance: Total cost of losses assumed to be prevented

2.2. Other Loss Prevention – other losses that may be ignored/ rarely quantified

3. Quantifying Loss Prevention.

3.1. Senior management will inevitably view all operations from a financial perspective because the department that plays a direct role in the generation of revenue is a profit center.

3.2. $ROI = \text{current value of investment} - \text{cost of the investment} / \text{cost of the investment}$

3.3. Three main expense categories : **Salaries, Opex, Capex**

3.4. Determining budget : **review org goals & strategies**

3.5. **Security Metrics** : process of measuring asset protection program effectiveness

4. Developing a Business Case.

- 4.1. Security professional must first understand and reach across the various departments to gain a holistic view of the enterprise and then be a skilled communicator to sell and advance the security position as a contributing partner to the overall mission of the business.
- 4.2. The most important aspect of the business case is how well it aligns with the organization's goals.
- 4.3. The business case must be realistic and have clear timelines for implementation and take into consideration outside factors that may delay full realization or implementation.
- 4.4. Must contain provisions for continuous improvement.
- 4.5. **Steps to write a Business Case** : Executive summary, Project description, Business impact, Justification, Cost benefit analysis, Alternatives & Analysis, Recommendation, Approval

Chapter - 5 : Information Asset Protection (IAP)

1. ESRM Approach to IAP.

- 1.1. Information assets consist of sensitive and proprietary information, privacy-protected data, intellectual property, intangible assets, and information defined under international, federal, and state laws governing trade secrets, patents, and copyrights.
- 1.2. **Steps** : Identify assets, identify risks, Mitigate Risks, Continuous improvement

2. Threat Categories : Intentional, Natural, Inadvertent

- 2.1. Counterfeit: manufacture or distribution of goods under someone else's name - without permission
- 2.2. Piracy: someone copies, reproduces, steals, transmits or sells intellectual property without consent

3. Risk Assessment & Due Diligence.

- 3.1. Risk assessments should identify risks, quantify them, and prioritize them according to the organization's criteria for risk acceptance.
- 3.2. Assessments should be performed regularly and should include risk monitoring to address changes in security requirements as well as changes in the nature of the information assets, threats, frequency of threat occurrence, vulnerabilities, and impacts.
- 3.3. monitoring helps in evaluating the effectiveness of security and other risk mitigation measures.
- 3.4. Impacts of proprietary information loss include loss of use, ownership, or control of intellectual property rights, as well as loss of proprietary information or prototypes that would facilitate product counterfeiting.
- 3.5. Ultimately, the responsibility for protecting information assets rests with the **leadership of an organization**, but it must be embraced by every other individual- inside or outside the company-who has access to the company's information assets.

4. **Physical Security Related to IAP.**

4.1. IAP professionals should coordinate closely with physical security staff to harmonize protective efforts in several categories.

4.2. **Layered Protection (Defense in Depth).**

4.2.1. This concept, which applies a vision of concentric rings or layers of protection to any asset, is most commonly thought of in terms of physical security.

4.2.2. Employed in protecting sensitive information assets.

4.2.3. Defense in depth can be viewed from three different perspectives, in which the concentric rings or layers of protection represent the following:

- Increasing levels of trust for those who are given access to successive layers.
- Different security technologies or measures that operate in concert. By applying overlapping and diverse security technologies and measures, security staff can identify and fill any gaps in protective coverage.
- Successive layers employed to delay, detect, and deter intruders. Each successive layer of protection may further delay an adversary, offer an additional opportunity to detect the intrusion, and deter an adversary from advancing.

4.3. **Protection of Information in Physical Form.**

4.3.1. **Prototypes & models.**

- These should be afforded all the same physical security, access controls, classification, employee vetting, verification, and documentation as other information assets.
- Obsolete prototypes, models, and test items should be destroyed so they cannot be reverse engineered.
- Contractors or vendors entrusted with prototypes, models, or test items should be contractually bound to protect them according to the owner's policies and procedures.

5. **Personnel Security.**

5.1. Personnel security plays a key role in IAP. It includes such matters as due diligence investigations of potential partners, standard preemployment screening, and vetting of subcontractors, vendors, and consultants.

5.2. The screening process often is outside the control of the security, risk management, or IAP functions and may instead be ***handled by the legal or human resources departments.***

6. **Travel & Meeting Security.**

6.1. Sensitive information may be particularly vulnerable when employees travel, attend trade shows, and participate in on- or off-site meetings.

6.2. **Domestic & International Travel.** Business travelers with any form of sensitive information can do the following to reduce the risk to that information:

6.2.1. Obtain a pre-travel security briefing or consult travel advisories, notifications, information services, and publications prior to departure.

6.2.2. Keep a low profile to minimize targeting.

6.2.3. Carry information on one's person, not in checked baggage.

6.2.4. Be aware of the risk of technical surveillance (electronic eavesdropping).

6.2.5. Avoid working on or discussing sensitive information in public areas.

6.2.6. Use computer privacy screens, cable locks, and other measures to protect information on computers.

6.2.7. Avoid the use of public Wi-Fi, hotel fax machines, copy facilities, and business centers for sensitive information.

6.3. **On- and Off-Site Meetings.** The following steps may help IAP professionals reduce the risk such meetings pose:

6.3.1. Obtain an annual schedule of the organization's strategic and critical business meetings and develop an IAP strategy for each meeting as necessary, based on risk assessment.

6.3.2. Before a venue is confirmed, obtain floor plans and details concerning the site's telecommunications and audiovisual infrastructure.

6.3.3. Arrange for a low-profile event when appropriate, minimizing signage and electronic postings of events, sponsors, room locations, and schedules.

7. **Copyrights.**

7.1. Under international law, copyrights do not have to be registered to be protected.

7.2. The copyright owner should not allow control of the copyright to fall into the hands of the organization's agents or distributors. It is important to do the following:

7.2.1. Incorporate copyright protections into contracts and marketing strategies.

7.2.2. Enter into written, enforceable contracts that require agents, suppliers, distributors, and employees to protect the copyright.

7.2.3. Refuse to assign or license the copyright until all consequences are fully understood.

7.2.4. Ensure that the copyright remains with the organization upon termination of the assignment, license, transaction, or investment.

8. **Patents.**

8.1. An inventor may protect an invention by patenting it or by deeming it a trade secret.

8.2. Patents convey a range of benefits but require that the inventor publicly disclose the invention's elements, and a ***patent lasts only 20 years.***

9. **Trade Secrets.**

9.1. Trade secrets need not be registered with any outside agency, so the owner can maintain a greater degree of control over the asset.

9.2. For information to be considered a trade secret, the owner must be able to prove that the information added value or benefit to the owner, the trade secret was specifically identified, and the owner provided a reasonable level of protection for the trade secret.

10. **Technical Protective Measures.**

10.1. **Technical Surveillance Countermeasures (TSCM).**

10.1.1. Technical surveillance countermeasures (TSCM) are services, equipment, and techniques designed to locate, identify, and neutralize technical surveillance activities (electronic eavesdropping).

10.1.2. TSCM should be part of an organization's overall protection strategy.

Chapter - 6 : Ethics & Legal Considerations

1. Ethics

- 1.1. Discipline or system of moral principles governing human actions & interactions.
- 1.2. Deals with right/ wrong of actions.
- 1.3. Ethical conduct – Legal, balanced, personal feelings.
- 1.4. Ethics as a discipline is divided into several types.
 - 1.4.1. **Descriptive** : describes the ethical events.
 - 1.4.2. **Analytical**: examine ethical conducts/ events.
 - 1.4.3. **Applied**: Prescribing laid down conduct.

2. Business Ethics.

- 2.1. Business ethics, then, is the field of ethics that examines moral controversies relating to business practices in any economic system.
- 2.2. Applied in levels: **individual, organization, Society**.

3. Ethics Problem

- 3.1. Factors for unethical conduct: desire, rationalization, opportunity
- 3.2. **Ethical Vs Legal**
 - 3.2.1. Causes for Poor ethical choices: **Convenience, Winning, Relativism**
 - 3.2.2. **Motivated Blindness** : people behave unethically out of self interest but remain unaware of it
- 3.3. **Instilling Ethics** : enforce Code of Conduct

4. Business Ethics Code & Program

<u>Ethics Code</u>	<u>Ethics Program</u>
Basis by which employees conduct their business & make decisions	Lays down the methods
States the underlying principles	program provides the guidance & structure for compliance
Statement of organizations shared values	
Built on traditions & personality of the organization: Corporate culture	

5. Legal Considerations

- 5.1. Sources of legal information – primary & Secondary
- 5.2. Primary : In-state or federal statute or case
 - 5.2.1. **Statutory Law** :
 - When approved by executive branch in the manner required by the constitution
 - Ordinance/ Local Law – Law passed by cities/ towns : *not referred as statutes*
 - Case law : Cases decided by the appellate courts & the decisions published as reporters

5.3. **Secondary** : Case, statute or journal from another state. Cannot be relied upon for legal argument

5.3.1. Law Review Articles – Initial source to understand law of the area. cases decided in the state

5.3.2. Trade Publications – Provide basic information, may be biased, *Last choice as legal reference*

6. Insurance as Risk Management Tool

6.1. **Insurance** is a formal undertaking between two parties-the insurer and the insured- under which the insurer agrees to indemnify or compensate the insured for specified losses from specified perils. ***It allows a business owner to transfer risk to an insurance company.***

6.2. Types of Insurance.

6.2.1. **Commercial General Liability** protects your business should you be liable for property damage or personal injury caused by your services, business operations, or your employees.

6.2.2. **Workers Compensation** provides medical expenses, lost wages, and rehabilitation costs to employees who are injured or become ill in the course of their job.

6.2.3. **Commercial Auto** provides physical damage and liability coverage to vehicles used in the course of your business.

6.2.4. **Commercial Property** provides coverage to protect commercial property from perils such as fire, theft, and natural disaster.

6.2.5. **Excess and Umbrella Liability** provides extra coverage for certain types of liability insurance by extending the limits provided under your primary policies.

6.2.6. **Fidelity Coverage** provides coverage against losses that are caused by your employees' fraudulent or dishonest actions

6.2.7. **Employment Practices Liability** Insurance provides coverage to employers against claims made by employees alleging discrimination, wrongful termination, harassment, etc.

6.2.8. **Directors and Officers Insurance** provides coverage for individuals from personal losses if they are sued as a result of serving as a director or an officer of a business or other type of organization.

6.2.9. **Cyber Insurance** provides coverage for financial losses that result from data breaches and other cyber events.

6.3. Insurance Providers. Insurance can be obtained through the following means:

6.3.1. Dealing directly with an insurance company;

6.3.2. Dealing with an insurance broker that may represent one or more insurance carriers;

6.3.3. Program administrators/managing general agents;

6.3.4. Risk retention groups are corporate bodies authorized under the laws of some states as liability insurance companies and are formed by groups/organizations of individuals/businesses that are engaged in similar businesses.

6.3.5. Captive carriers.

Chapter – 7 : Business Principles

1. Management & Leadership.

1.1. The distinction between managers and leaders is often marked by the differences in individual motivation, personal history, and in how they think and act.

1.2. Management.

1.2.1. **Definition.** Set of activities directed at the efficient and effective utilization of resources in the pursuit of one or more goals.

1.3. Management involves coordinating and overseeing the work activities of others so it is completed efficiently and effectively. **Management is a complex process.**

1.4. **Managers.** Managers are people who coordinate the work of others in order to achieve stated organizational goals.

1.4.1. A manager's job is about helping others do their work.

2. Critical Thinking.

2.1. Critical thinking is the use of knowledge and intelligence to arrive at justifiable positions on which to base decisions.

2.2. Critical thinking is based on qualities that have universal value- **clarity and accuracy, consistency and relevance, depth and breadth, and integrity and fairness.**

2.3. Critical thinking creates knowledge and improves organizational learning necessary for strategic, conceptual, innovative, and integrative work.

3. The Concept of Strategy.

3.1. A strategy is a goal-oriented set of plans and actions that enable a business to compete effectively.

3.2. **Strategy Vs Tactics.** Strategy is about the plans to achieve an established goal while tactics must be aligned with strategy, they are the adaptive actions taken during the effort to achieve that goal.

3.3. Security must ensure that their strategies, objectives, and goals are aligned with those of the larger company.

4. External Competition.

4.1. The external business environment consists of economic, demographic, socio-cultural, political-legal, technological, and international-global sectors.

4.2. When threats are very high, competition in an industry begins to approach what is called **perfect competition**. When all threats are very low, competition in the industry is looked upon by economists as a **monopoly**.

4.3. **Perfect competition** occurs when there are large numbers of competing firms, the products being sold are homogenous with respect to cost and attributes, and the cost for market entry or exit is low.

4.4. **Monopolistic competition**

4.4.1. When an industry has large numbers of competing firms and a low cost of entry into and out of the industry.

4.4.2. Monopolistic industries consist of a single firm, and entry into such an industry is very costly.

4.5. **Oligopolies** are characterized by a small number of competing firms with homogenous products and high industry entry and exit costs.

4.6. Two strategically relevant factors and elements influence a firm's performance: ***the macro environment and the immediate industry and competitive environment.***

Chapter – 8 : Crisis Management

1. Emergency Management.

1.1. Emergency management/response is the planning and activity associated with detecting, containing, and dealing with the immediate impact of an event.

1.2. ***Mitigation*** is the process of putting protective measures in place to reduce the likelihood of a disaster occurring, or to reduce the impact if a disaster does occur. Mitigation tries to lessen the harm in advance of an event.

1.3. ***Preparedness*** encompasses any activities, programs, and systems developed and implemented prior to an incident that may be used to support and enhance mitigation of, response to, and recovery from disruptions, disasters, or emergencies.

1.4. ***Response*** deals with executing the plan and performing duties and services to preserve and protect life and property as well as provide services to the surviving population.

1.5. ***Recovery*** ensures that the processes, resources, and capabilities of the organization are reestablished to meet ongoing operational requirements.

2. Crisis Management.

2.1. ***Crisis management*** is strategic and refers to the process of supporting emergency management/response and business continuity operations while dealing strategically with the numerous issues that could impact the long-term viability of the organization.

2.2. Crisis management begins upon notification of any disruptive event-both physical emergencies and non-physical events such as product recalls and regulatory, legal, or financial issues.

2.3. ***The ultimate goal of crisis management is to protect core assets of the organization.***

3. **Business Continuity Management.** Business continuity refers to the processes and procedures put in place to move from functioning during the crisis to functioning as normal operations after a business interruption.

Process | Performance | Protection

Chapter – 9 : Investigations Management

1. Investigations Management.

1.1. ***“Investigation”***: A systematic and thorough examination or inquiry into something or someone (the collection of facts and information) and the recording of that examination in a report.

- 1.1.1. Applies equally in both the public and private sectors
- 1.1.2. Clearly covers the broad range of investigations, from background checks to administrative inquiries to, criminal matters
- 1.2. Purpose of conducting Investigations.
 - 1.2.1. Documenting incidents
 - 1.2.2. Identifying the cause of undesirable situations
 - 1.2.3. Documenting and correlating facts
 - 1.2.4. Identifying suspects
 - 1.2.5. Compiling information to prove/disprove allegations or implicate/exonerate suspects
 - 1.2.6. To make a decision

2. Qualities of Effective Investigation.

2.1. Objectivity

- 2.1.1. The ability to remain objective and focused; allowing information, evidence, and interviews to be reported without internal or external biases.
- 2.1.2. Objectivity requires setting aside personal feelings, opinions, and external influences.
- 2.1.3. This can be one of the most difficult requirements for the investigator- because it defies human nature.
- 2.1.4. A logical hypothesis begins with understanding the existing information, evidence, and context of the investigative mission.

2.2. Thoroughness

- 2.2.1. Corroborating important aspects through different sources is a proven means of achieving thoroughness.
- 2.2.2. Different types of sources should be consulted to the greatest extent possible.
- 2.2.3. The investigator must also corroborate statements by witnesses and the subject of interest.
- 2.2.4. It is imperative to document all leads and information-they may seem irrelevant at the time but later become important to the investigation.

2.3. Relevance

- 2.3.1. Effectively determining whether information applies to the case, considering an adequate spectrum and depth of details without gathering so much data as to confuse the facts of the case and bog down the investigation or possibly even obscure the truth.
- 2.3.2. The information in question must pertain to the subject of the investigation in some way and with the appropriate level of detail.
- 2.3.3. The appropriate depth of detail is difficult to achieve with some interviewees, especially those who may be **less intelligent or very intelligent** (e.g., scientists and engineers) or people who are nervous, in a hurry, attempting to hide something, or simply very quiet or very talkative.
- 2.3.4. The investigator's job is to ask **open-ended questions** that allow for the free flow of information.

2.4. Accuracy

- 2.4.1. The credibility of a source, whether human, physical, or electronic evidence, or the result of observation or surveillance.
- 2.4.2. Eyewitnesses make mistakes and that their memories can be affected by various factors including the very law enforcement procedures designed to test their

memories". According to The Innocence Project, mistaken eyewitness identifications contributed to more than **70 percent** of the wrongful convictions in the United States.

2.4.3. In the corporate environment, much credible information on losses, sexual harassment, and other reportable incidents comes from employee tips.

2.4.4. If an informant is the **only source of key data**, the informant should be tested at least for consistency. In addition, the information itself must be tested for inherent contradictions.

2.5. **Timeliness**

2.5.1. The ability to complete an investigation quickly, but not too quickly, and to resist pressure by outside forces to inappropriately either rush or stall a case, thereby damaging the quality of the resolution.

2.5.2. In investigations, it is important to:

- Open an investigation as soon as possible,
- Complete an investigation as quickly as possible, and
- Avoid closing an investigation prematurely.

3. **Undercover Investigations.**

3.1. Surreptitious placement of a properly trained and skilled investigator, posing as an employee, vendor, or customer, into an unsuspecting workforce for the primary purpose of gathering information.

3.2. Undercover operations are, by nature, covert operations.

3.3. Undercover investigations are complicated and are not suitable in all environments.

3.4. The chief distinction between undercover and other types of investigations is that the undercover investigator neither conceals his or her presence nor attempts to operate unnoticed.

3.5. Form of interactive investigation.

3.6. **Use Cases** – Employee misconduct, Consistent losses, Drug abuse, Comparison of work practices

3.7. **Not to be conducted.**

3.7.1. Not to be used to gather information of personal & confidential nature

3.7.2. Not to investigate any activity permitted or protected by Govt rule or regulation

3.7.3. When any other form of investigation will provide same result

3.7.4. Not to investigate protected Union activities

Chapter -10: Personnel

- Security Mission depends on **people**.

1. **Security Officer Utilisation**

1.1. Security officers are best used as part of the complete protection plan and not as a stand alone resource.

1.2. Security management plans are based on understanding of the risks they are designed to control.

2. **Security Officers.**

2.1. **Security officers** are the costliest item in the organizations security budget.

2.2. Basic Functions

2.2.1. Access Control - *Primary function of security officer*

- 2.2.2. Patrol - *Foot & Vehicular, Observation is prime task of patrol officer*
- 2.2.3. Escort - *NOT for visitors /customers*
- 2.2.4. Emergency response
- 2.2.5. Dealing with disruptive people - *requires sensitivity, goal to prevent harm*
- 2.2.6. Public Relations - *uncooperative employee to be referred to a supervisor for admin action*
- 2.2.7. Special Assignments

3. Weapons.

3.1. Firearms.

3.1.1. The decision whether to arm an officer should be based on the existence of one or both of the following conditions:

- There is a greater danger to life safety without the weapon.
- The officer may reasonably be expected to use fatal force.

3.1.2. If officers are armed, the management of the facility assumes several responsibilities:

- Proper training of the officers to be armed;
- Selection of the appropriate firearms and ammunition;
- Proper maintenance of the firearms by a qualified gunsmith;
- Maintenance of records of the foregoing actions; and
- An adequate level of liability insurance.

3.1.3. Firearms may be appropriate when large amounts of cash are regularly handled and robbery is a risk.

3.1.4. The strategic value of issuing weapons is that potential assailants may be dissuaded from attacking a target if they know they will face armed resistance.

3.2. Less than Lethal Weapons

3.2.1. A full analysis of "will the benefits outweigh the risks" should be conducted.

3.2.2. Listed below are the most common types of less than lethal weapons.

- **Electroshock weapons.** These defensive weapons use electricity to stun or disable a subject. There are three common types: the TASER, the stun gun, and the stun baton.
- The **TASER** (a registered trademark) uses compressed gas to fire two barbed probes towards a target. The subject's neurological system is affected, and the target will generally lose control of muscles.
- Using a **Stun Gun** requires the officer to directly contact the subject with the device. Stun guns and stun batons may cause pain without disabling the subject. Also known as conducted electrical weapons (CEW) or conducted energy devices (CED), these weapons effects are temporary, but may stop aggressive action.
- **Batons.** Perhaps one of the most utilized less than lethal weapons in security is the baton. Batons may be composed of wood, metal, or a plastic like resin. Improper use of a baton can cause great bodily injury and/or death.
- **Aerosol irritants.** The carrying of aerosol irritants or chemical agents by security officers is common. CS (2-chloroacetophenone), CN (0-chlorobenzylidene), and OC (oleoresins capsicum) are among the most frequent chemical compounds used. Commonly referred to as "**tear gas**" or "**pepper spray**," they are designed to irritate the mucus membranes and the eyes causing tearing, coughing, difficulty breathing, and skin irritation.

4. Proprietary Vs Contract Officers.

4.1. The decision of what type of security force to use should be based on factors such as the type of assets being protected, the level of risk, and the expectations of the officers instead of cost.

4.2. Proprietary Officers & Contract Officers Differences.

 CONTRACT SECURITY OFFICERS	 PROPRIETARY/IN-HOUSE SECURITY OFFICERS
• May be regulated by local licensing authorities	• Regulated by employer
• Hiring criteria set by licensing authority, contract stipulations, and employer's policies	• Hiring criteria set by employer
• Often receive less specific training, possibly less supervision	• Usually receive more training, supervision
• Work at varied settings, changing schedules	• Usually have consistent schedules
• Contract-driven work conditions	• Employer-driven work conditions
• High turnover typical	• Generally better retention
• Loyalty to contract provider	• Loyalty to hiring organization
• Inclined towards short-term assignments	• Longer term assignments
• May need flexibility to report to multiple bosses; chain of command is less clear	• Clear chain-of-command
• Less integrated into or part of workplace	• More integrated into and part of workplace
• May require adaptability for frequent retraining on different sites/assignments	• More progressive site-specific training
• Lower hiring and overall costs	• Higher hiring and overall costs
• More job oriented	• More career oriented

5. Types of Security Consultants.

5.1. Security consultants can be classified into three major categories: security management consultants, technical security consultants, and security forensic consultants.

5.2. **Security Management Consultants.** Specialise in certain discipline, which comprises the foundation of their expertise.

5.3. **Technical Security Consultants.**

5.3.1. Have specialised subject matter or technical expertise.

5.3.2. Specialize in translating the concepts and functionality provided by the security management consultant.

5.3.3. Also provide management services -writing security procedures & policies.

5.4. **Forensic Security Consultants.**

5.4.1. Deal with investigation, identification and collection of evidence.

5.4.2. Referred as an expert witness in civil lawsuits.

5.5. **Security Advisory Committee.**

5.5.1. Internal resource formed to assist corporate executives & CSO to ensure current security measures are adequate.

5.5.2. Committee is chaired by a project coordinator and reviews the security programme at least **quarterly**.

6. Selecting a Security Consultant.

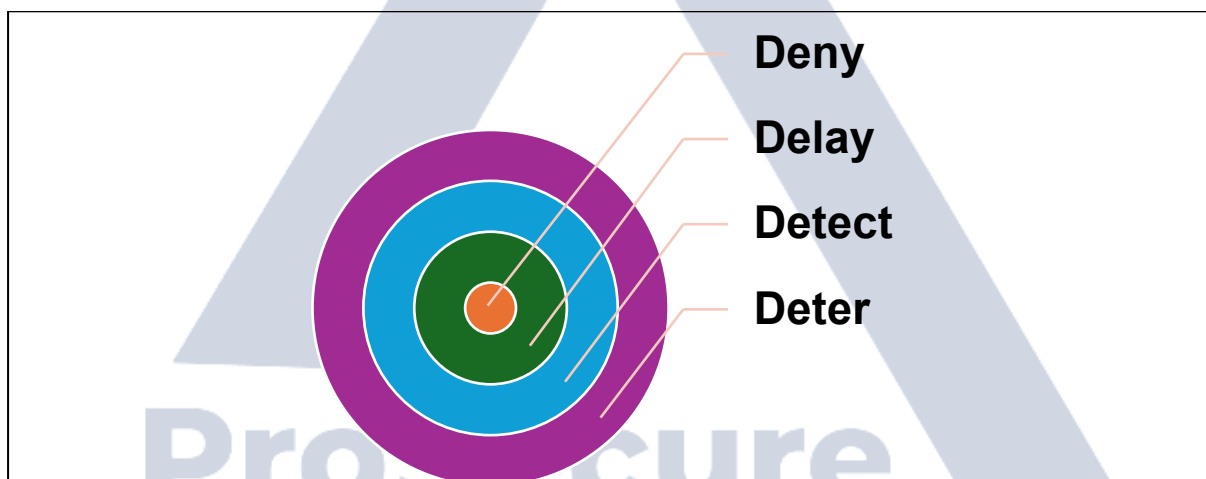
6.1. As a guide, and after defining the scope of work, the following five steps can be used when selecting a consultant:

- 6.1.1. Step 1: Identify candidates.
- 6.1.2. Step 2: Invite candidates to submit an application.
- 6.1.3. Step 3: Evaluate the applications.
- 6.1.4. Step 4: Interview the top two to three candidates.
- 6.1.5. Step 5: Negotiate an agreement and finalize the selection.

Chapter – 11: Physical Security

1. Functions of Physical Security.

- 1.1. The purpose of physical security is to protect assets, whether they are tangible, intangible, or mixed and whether they take the form of people, property, or information.
- 1.2. The concept of the **four Ds** should form the basis for all physical security projects. Physical security measures must be considered in the context of their ability to deter an adversary, detect an attack, delay an attack, and deny an adversary access to the target.



2. Physical Security Assessments & Risk Assessment Models.

2.1. A thorough and accurate understanding of the security risk is critical to any physical security project-whether a complete system design or a simple component upgrade.

2.2. **ESRM Process:** the first step is to understand the context, continuing with the ESRM cycle, first identifying the assets and continuing to identify and prioritise the risk.

2.3. **Comprehensive Risk Assessment:** Begins by identifying and placing some value (either absolute or relative) on the organization's assets followed by an evaluation of the relevant threats to those assets, and then conducting the vulnerability assessment. Consideration is then given to the potential impact of a loss event (such as an attack, theft, or property damage), as well as means of summarizing and prioritizing the revealed risks. Finally, risk mitigation measures are recommended and ultimately blended into a comprehensive protection strategy.

3. **Physical Security Metrics.**

3.1. In a world of tight budgets and increased regulations and oversight, executives continually hold their managers to a higher standard of performance and accountability.

3.2. Metrics show the status of a program, identify performance trends and demonstrate the ROI or value-added for a program, all within the context of the existing corporate culture.

3.3. Metrics measure the **effectiveness and efficiency** of an organization's operations over time.

4. **Design Concepts.**

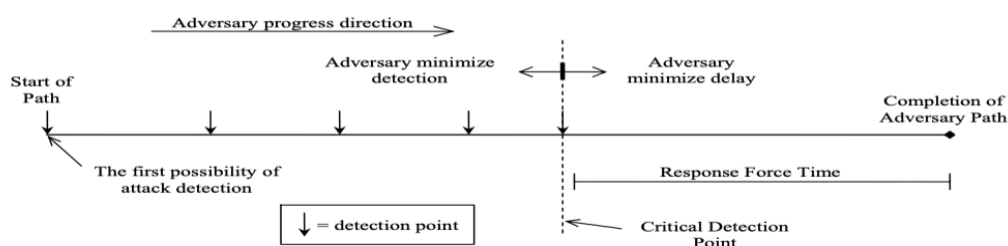
4.1. Any physical security project to be successful, must incorporate basic design concepts at all phases, especially the planning and early design phases.

4.2. Security risk management precepts should be applied to every aspect of a comprehensive protection strategy.

4.3. The two foundational principles are the four Ds (deter, detect, delay, and deny) and layered security (defense-in-depth or security-in-depth).

4.4. Layers should bolster one another and serve as mutual backup-all without overdesign or unnecessary duplication.

4.5. The critical detection point is defined as the point where the **delay time remaining exceeds the response force time.**



4.6. Layers may convince the perpetrator to abort the attempt and find a softer target.

5. **Integrated Security & Protection Strategies.**

5.1. Interaction of multiple electronic security systems as a program is beneficial and a complex challenge.

5.2. Security systems ride on a network backbone – Independent or enterprise.

5.3. To avoid complexities in the system, it is recommended to select a single source to take responsibility for the systems preventive & remedial maintenance.

5.4. Physical security elements are generally categorized as **Electronic security systems, structural security measures and Human capital.**

6. **Structural Security Measures & CPTED.**

6.1. Structural security includes : overall structure of the building, physical barriers, locking systems & lighting.

6.2. Crime Prevention Through Environmental Design (CPTED).

6.2.1. Based on common sense and heightened awareness about how people use their space for legitimate and criminal intentions.

6.2.2. CPTED is a crime prevention theory grounded in environmental criminology—namely, the proposition that carefully designed places can deter opportunities for crime.

6.2.3. CPTED is a set of management tools that target the following.

2. **Places.** Physical environments (such as office buildings, parking garages, parks and public spaces, multifamily apartment buildings, warehouses, schools, houses of worship, and shopping centers) can be designed to produce behavioral effects that reduce the opportunity for certain types of crime.

3. **Behaviour.** Some locations seem to predict, create, promote or allow criminal activity while other environments elicit law abiding conduct.

4. **Design & Use of Space.** Redesigning a space or using it more effectively can encourage desirable behaviour and discourage crime.

5. Three underlying elements of CPTED are **Territoriality, Surveillance and Access Control.**

6. CPTED measures : **Mechanical, organizational, Natural.**

7. Access Control.

7.1. Electronic access control systems validate one or more credentials, which can be in the form of Something you know, something you carry or something that is inherent to you.

7.2. Verification decision is usually based on determining whether the person:

7.2.1. Is carrying a valid credential,

7.2.2. Knows a valid personal identification number,

7.2.3. Possesses the proper unique physical characteristic that matches the person's characteristic recorded at enrollment (biometrics, such as fingerprint, hand geometry)

7.3. These three concepts are summarized as what you have, what you know, and what you are.

8. Security Officers.

8.1. Security officers remain an important and often essential component of many integrated asset protection strategies.

8.2. Security officers are now used in more environments than ever before. In some cases, they are replacing public police or soldiers.

9. Project Management.

9.1. Project management involves : Planning, organizing & controlling the resources.

9.2. Project differs from ordinary operations in that projects are temporary efforts with a defined beginning and end.

9.3. Projects are undertaken to meet specific goals and objectives, typically to benefit the organization in some very specific way.

9.4. A security-related project may be specific to the security mission, or it may be the security portion of a project for the larger organization.

9.5. Projects typically are limited in both time and budget.

9.6. The challenge of project management is to achieve all the project goals and objectives while living within the project's time and budget constraints.



9.7. Systems Design.

9.7.1. A system in the security context is a combination of equipment, personnel, and procedures, coordinated and designed to ensure optimum achievement of the system's stated objectives.

9.7.2. A protective system is evaluated on its **performance and cost-effectiveness** in countering threats, reducing vulnerabilities, and decreasing risk exposure.

9.7.3. The process also applies to the design, procurement and deployment of other security elements.

9.7.4. System design starts with planning and assessment.

- First task is to conduct a risk assessment.
- The second task is to analyze security requirements and formulate solutions or countermeasures concepts to reduce or eliminate vulnerabilities and mitigate risks.

9.7.5. The **output of the design phase** is systems hardware, software identification and placement, integration, and performance documentation that is sufficiently clear and complete to ensure consistent, accurate interpretation by suppliers and installers for systems procurement and implementation.

9.7.6. System design is a serial process. Each phase and task must be performed before the next can begin; the output from one task becomes the input for the next.

9.7.7. Moreover, if the PPS project is part of a facility's major construction or upgrade project, PPS design and implementation will be executed and documented according to the schedules and documentation of architectural design and construction, normally managed by a certified architect as project overseer.

9.8. System Implementation.

9.8.1. Project and system implementation begin immediately following the selection of a contractor and involves these steps:

- Site preparation;
- Contractor coordination;

- Installation;
- Testing and warranty issues; and
- Training.

9.8.2. The most important step in installing physical protection system elements is **site preparation and planning.**

- The contractor should visit the site and verify that conditions agree with the design package.
- The contractor should be required to prepare a written report of all changes to the site or conditions that will affect performance of the system.
- The contractor should be instructed not to take any corrective action without written permission from the customer.
- The contractor should not disconnect any signal lines or equipment or create any equipment downtime without prior written approval of the customer.
- The ideal acceptance tests stress the system up to the established limits of the site specific threats. Tests should simulate actual threat conditions and provide conclusive evidence about the effectiveness of the security system.

9.8.3. **Follow-on & Support Activities.**

- Every security system requires regular maintenance, and maintenance planning must be an essential component of the system design if the security system is to succeed in its mission.
- The greatest emphasis for support on equipment must be placed on that which has the greatest impact on the overall system should it fail.
- System selected should have maintenance support in local market post installation.

Chapter -12: Global Trends in Security

1. **Civil Unrest.**

- 1.1. A significant threat. Protests & riots are unstable, high tension events that can have outcomes as serious as loss of life, severe injuries, property damage and business disruption.
- 1.2. Causes. Social injustice, climate change, economic policy, govt decisions & policies.
- 1.3. Impact: Physical protection of facilities, safety of employees & reputational risk.
- 1.4. The goal of security in civil unrest is not arrest protestors but to prevent problems.

2. **Terrorism.**

2.1. **Definition.**

- 2.1.1. Terrorism is an act of violence designed to achieve a political end. Used by both state & non-state actors.
- 2.1.2. UN Definition: Any action if it is intended to cause death or serious bodily harm to civilians or non-combatants, with a purpose of intimidating or compelling a Govt to do or abstain from doing any act.

2.2. **Primary Goal of Terrorism.**

2.2.1. To target public's sense of security.

2.2.2. Promote a specific ideology.

2.2.3. The victims & locations of terrorist attacks are carefully selected to add the impact of the incident.

2.3. **Terrorism Tactics.** Employment of both conventional & cyberattack vectors.

3. **Workplace Violence.**

3.1. A spectrum of behaviors, including overt acts of violence, threats and other conduct that generates a reasonable concern for safety from violence.

3.2. These threats and risks can emanate from internal or external sources.

3.3. Consequences: Loss of life, injuries. Business related concerns – liability, productivity, Business disruption.

3.4. Workplace Violence Prevention program.

4. **Cybersecurity.**

4.1. Cybersecurity incidents cost money.

4.2. Cybersecurity program to protect the CIA Triad.

4.3. Internal Theft Risks. Unapproved personal devices, Public Wi-Fi, remote workers.

4.4. Types of Attacks.

4.4.1. **Phishing.**

Phishing is a form of online fraud in which hackers attempt to get your private information such as passwords, credit cards, or bank account data. This is usually done by sending false emails or messages that appear to be from trusted sources like banks or well-known websites.

Social Engineering attack, an attacker uses human interaction (Social Skills) to obtain or compromise information about an organization or its computer systems.

4.4.2. **Ransomware.**

- The process of encrypting a user's files and then demanding payment to decrypt them. Also known as crypto-ware.

- Often introduced into the networks via phishing, Trojan attacks, compromised credentials or software vulnerabilities.

4.4.3. **Business Email Compromise Schemes (BECs).** Malicious actors pose as an executive to initiate a wire transfer to an account controlled by criminals.

4.4.4. **Intellectual Property Theft.** Sensitive information to include trade secrets and confidential information.